

From Manual to Evidence-Based CVSS Environmental Assessment: A Multi-Agent Automation Case Study with AI Bridge

Wagner Santos

[Co-authors to be completed]

May 18, 2026

Abstract

Environmental metrics in the Common Vulnerability Scoring System (CVSS) allow assessors to adapt vulnerability severity to the deployment context of an organization. Prior empirical work showed that human assessment of these metrics becomes error-prone as network segmentation and system dependencies increase. This paper proposes an evidence-based automation workflow using AI Bridge, a local multi-agent execution framework that can read environment files, run controlled commands, coordinate independent agent reviews through watchers, and produce auditable CVSS Environmental assessments. We present a PCI-DSS inspired case study in which AI agents replace human subjects and derive environmental metrics from structured evidence: asset inventory, network topology, firewall rules, business impact, PCI scope and vulnerability findings. The expected contribution is not an autonomous replacement for expert judgment, but a reproducible and auditable process for generating CVSS Environmental vectors with explicit evidence and review traces.

1 Introduction

The Common Vulnerability Scoring System (CVSS) is widely used to communicate the severity of software vulnerabilities. In practice, however, organizations often rely on the Base score only, even though the real operational severity of a vulnerability depends on local deployment conditions, business criticality, security requirements, and mitigating controls.

A previous controlled experiment on CVSS Environmental Metrics showed that manual assessment does not scale well with environmental complexity. In that study, assessors were more accurate in a flat network than in a segmented network, and system-level vulnerabilities were harder to assess correctly than application-level vulnerabilities in segmented environments [1]. The study concluded that automation and data integration are necessary for environmental assessments to become practical at organizational scale.

This paper continues that line of research. Instead of running another human subject experiment, we investigate whether a local multi-agent automation framework can perform the environmental assessment task by collecting and reasoning over evidence. We use AI Bridge as the execution substrate. AI Bridge can read local files, run controlled commands, coordinate messages through a watcher, relay tasks across chats or agents, and produce auditable artifacts.

The main research question is:

Can tool-augmented AI agents, operating through AI Bridge, generate reproducible and evidence-backed CVSS Environmental assessments for segmented PCI-DSS-like environments?

2 Background

2.1 CVSS Environmental Metrics

CVSS version 4.0 organizes vulnerability scoring into Base, Threat, Environmental and Supplemental metric groups [5]. The Base metrics describe intrinsic properties of a vulnerability, while Environmental metrics are intended to adapt severity to the consumer’s environment. The NVD provides CVSS calculators and supports CVSS v4.0, but environmental assessment depends on local organizational context [9, 8].

This artifact initially implements CVSS v3.1 Environmental scoring because it is directly comparable with the previous CVSS 3.x experimental setup. The workflow focuses on security requirements (CR, IR, AR) and selected Modified Base metrics such as Modified Attack Vector (MAV). The paper positions CVSS v4.0 support as the next natural extension.

2.2 PCI-DSS Scope and Vulnerability Prioritization

PCI-DSS scoping separates systems that process or can interact with cardholder data from systems outside the cardholder data environment. In the original experiment, the same conceptual model was used to test whether assessors could correctly adapt Environmental metrics before and after segmentation.

3 Related Work and Gap

CVSS is the reference scoring vocabulary for many vulnerability-management workflows. CVSS v3.1 organizes metrics into Base, Temporal, and Environmental groups, while CVSS v4.0 reorganizes the model into Base, Threat, Environmental, and Supplemental groups. This distinction is important for the present work because Base metrics describe intrinsic vulnerability properties, whereas Environmental metrics describe characteristics that are unique to the consumer’s deployment environment [4, 5]. The official CVSS v4.0 specification explicitly recommends enriching Base metrics with Threat and Environmental values when the consumer needs a score that better reflects organizational risk context [5].

Public vulnerability data sources do not usually solve this environmental-assessment problem for the consumer. The NVD provides CVSS enrichment for published CVE records, but its assessment is primarily based on Base metrics and it does not currently provide Environmental, Threat, or Supplemental metric assessments for a specific consuming organization [10]. This creates the operational gap addressed by this paper: the information needed for environmental scoring is normally local to the organization, distributed across asset inventory, topology, firewall rules, business impact, and compliance scope.

Alternative prioritization frameworks address related but different problems. SSVC structures vulnerability response as a stakeholder-specific decision process, reducing reliance on one-size-fits-all scoring and emphasizing decisions that match the stakeholder’s context [12, 2]. EPSS estimates the probability that a vulnerability will be exploited in the wild, providing a threat-likelihood signal that complements severity scoring [7, 6]. These approaches are useful for prioritization, but they do not by themselves derive CVSS Environmental metrics such as security requirements or modified attack vector from local network evidence.

Prior environmental-scoring work is closest to the present study. Eitel proposed Environmental Aware Vulnerability Scoring, arguing that Environmental metrics are frequently ignored and that systematic automation requires information about systems and networks represented in a model [3]. The present work follows the same evidence-integration premise but uses the AI Bridge watcher as an execution and audit layer: it can read structured local artifacts, coordinate specialized review roles, regenerate outputs, and preserve an inspectable trace.

Recent work on language models and vulnerability scoring has focused mainly on automated CVSS prediction from vulnerability descriptions. AutoCVSS evaluates LLMs for automated software vulnerability scoring [11], and EvalSVA studies multi-agent evaluators for software vulnerability assessment [13]. These systems are relevant because they show that LLMs and multi-agent designs can support vulnerability assessment tasks. However, their primary input is vulnerability text or code-related evidence, not organization-specific environmental artifacts. The remaining gap is therefore a reproducible workflow that connects local environmental evidence to CVSS Environmental metrics and records why each metric value was selected.

4 AI Bridge Approach

AI Bridge is used as a local execution and orchestration layer. The intended workflow is shown in Figure 1.

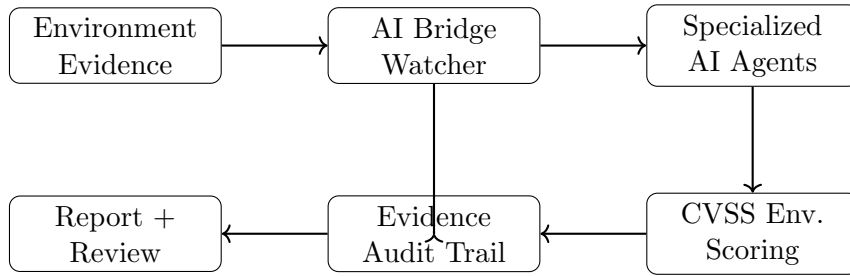


Figure 1: Evidence-based CVSS Environmental assessment workflow using AI Bridge.

We define four agent roles:

1. Network/Topology Analyst;
2. PCI-DSS Scope Reviewer;
3. CVSS Environmental Analyst;
4. Evidence Consolidator.

The agents do not simply output a score. Each metric value must reference evidence, such as asset inventory, business impact classification, firewall rules, topology, or vulnerability metadata.

5 Case Study Design

The case-study design follows the logic of the prior PCI-DSS inspired experiment: compare environmental assessment under flat and segmented network conditions. The new study adds machine-readable evidence artifacts so that the same type of scenario can be assessed by deterministic scripts, language-model agents, and a watcher-enabled multi-agent workflow.

Each case is represented by:

- an asset inventory;
- vulnerability findings;
- network topology;
- firewall rules;
- business-impact mappings;
- PCI scope declarations; and

- expected expert labels used only for evaluation.

The experimental comparison includes four conditions:

1. historical human-baseline findings from the prior study;
2. a deterministic rule-based baseline;
3. a language-model baseline without local tool access; and
4. the AI Bridge watcher workflow with local evidence access.

The main outcomes are exact match against expert labels, environmental score error, correct direction of before-after change, reproducibility across repeated runs, and evidence coverage. Evidence coverage is defined as the proportion of scoring decisions that can be traced to a concrete artifact such as an asset record, topology entry, firewall rule, PCI scope declaration, or business-impact statement.

6 Artifact and Implementation

The artifact is organized as a reproducible starter kit. The Python application loads structured case files, applies transparent inference rules, computes CVSS v3.1 Environmental scores, and writes JSON, CSV, JSONL and Markdown outputs.

The AI Bridge folder contains watcher command templates and agent prompts. These files are intended to operationalize the case study through real AI Bridge execution: local file reading, command execution, chat-to-chat review, and evidence consolidation.

The artifact produces an `audit_trace.jsonl` file where each line links a metric decision to a source and a reason. This is the core mechanism that turns the assessment from an opaque AI output into an auditable procedure.

7 Preliminary Evaluation Plan and Baseline Results

The current artifact includes a clean deterministic validation run for the PCI segmented lab case. The run is stored in `outputs/runs/pci_segmented_lab_20260517_143146/` and is accompanied by `run_manifest.json`, input hashes, generated assessments, an audit trace, and a before-after comparison table. These results are treated as artifact-validation results, not as evidence that the watcher workflow outperforms human experts.

The run generated 12 assessments for six findings, with one before and one after segmentation assessment per finding. All generated CR, IR, AR, and MAV labels matched the expected expert labels included in the structured case files. Two findings were downgraded after segmentation, four remained unchanged, and none were upgraded. The mean environmental-score delta was -0.267 and the maximum absolute delta was 0.8.

Table 1: Clean deterministic before-after run for the PCI segmented lab case.

Finding	Asset	Type	MAV	Before	After	Delta	Effect
F-001	A-CORP-SRV	SYS	N-A	8.8	8.0	-0.8	downgraded
F-002	POS-01	SYS	L-L	7.8	7.8	0.0	unchanged
F-003	ADMIN-01	APP	N-A	8.8	8.0	-0.8	downgraded
F-004	WIRELESS-LEGACY-01	APP	N-N	7.8	7.8	0.0	unchanged
F-005	CORE-SW-01	SYS	A-A	9.7	9.7	0.0	unchanged
F-006	CORE-SW-01	SYS	A-A	8.8	8.8	0.0	unchanged

The final evaluation will compare four conditions: historical human baseline, deterministic rule-based baseline, language-model baseline without local tool access, and AI Bridge watcher-mediated multi-agent assessment with local evidence access. The primary metrics are exact match for CR, IR, AR, and MAV; secondary metrics include environmental-score error, correct before-after direction, reproducibility across repeated runs, evidence coverage, and audit-trace completeness.

8 Threats to Validity

The main construct validity risk is that structured case files may simplify real enterprise environments. This is mitigated by explicitly representing topology, scope, firewall rules, business impact and vulnerability metadata.

The main internal validity risk is that rule-based inference may encode the expert judgment instead of discovering it. For this reason, the multi-agent version should be executed separately and compared to the expert label file.

The main external validity risk is that one PCI-DSS-inspired case may not represent other regulated environments. The artifact is therefore designed to allow additional case folders.

9 Conclusion

This paper proposes a continuation of prior empirical work on the difficulty of CVSS Environmental assessment. The central claim is that the next step is not another purely manual study, but an evidence-based automation workflow that allows AI agents to collect, interpret, justify and audit environmental metric decisions.

AI Bridge provides the operational substrate for this workflow: local file access, controlled command execution, watcher-mediated agent coordination, and artifact generation. The initial case study and Overleaf template included in this package provide the starting point for a full paper and reproducible research artifact.

References

- [1] Luca Allodi, Silvio Biagioni, Bruno Crispo, Katsiaryna Labunets, Fabio Massacci, and Wagner Santos. Estimating the assessment difficulty of cvss environmental metrics: An experiment. In *Future Data and Security Engineering*, volume 10646 of *Lecture Notes in Computer Science*, pages 23–39. Springer, 2017.
- [2] Cybersecurity and Infrastructure Security Agency. Stakeholder-Specific Vulnerability Categorization (SSVC). <https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc>, 2024.
- [3] Andreas Eitel. Environmental aware vulnerability scoring. In *Proceedings of the 9th International Conference on Internet of Things, Big Data and Security*, pages 401–407. SCITEPRESS, 2020.
- [4] Forum of Incident Response and Security Teams. Common Vulnerability Scoring System Version 3.1: Specification Document. <https://www.first.org/cvss/v3.1/specification-document>, 2019.
- [5] Forum of Incident Response and Security Teams. Common Vulnerability Scoring System Version 4.0: Specification Document. <https://www.first.org/cvss/v4.0/specification-document>, 2023.

- [6] Forum of Incident Response and Security Teams. Exploit Prediction Scoring System (EPSS). <https://www.first.org/epss/>, 2024.
- [7] Jay Jacobs, Sasha Romanosky, Benjamin Edwards, Idris Adjerid, and Michael Roytman. Exploit Prediction Scoring System. <https://arxiv.org/abs/1908.04856>, 2021.
- [8] National Vulnerability Database. CVSS v4.0 Official Support. URL: <https://nvd.nist.gov/vuln-metrics/cvss>, 2024.
- [9] National Vulnerability Database. Vulnerability Metrics. URL: <https://nvd.nist.gov/vuln-metrics/cvss>, 2024.
- [10] National Vulnerability Database. Vulnerability Metrics. <https://nvd.nist.gov/vuln-metrics/cvss>, 2024.
- [11] Davide Sanvito, Giovanni Arriciati, Giuseppe Siracusano, Roberto Bifulco, and Michele Carminati. AutoCVSS: Assessing the Performance of LLMs for Automated Software Vulnerability Scoring. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing: Industry Track*, pages 564–575. Association for Computational Linguistics, 2025.
- [12] Jonathan M. Spring, Eric Hatleback, Art Manion, Deana Shick, and Christopher Alberts. Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization. Technical report, Software Engineering Institute, 2021.
- [13] Xin-Cheng Wen, Jiaxin Ye, Cuiyun Gao, Lianwei Wu, and Qing Liao. EvalSVA: Multi-Agent Evaluators for Next-Gen Software Vulnerability Assessment. <https://arxiv.org/abs/2501.14737>, 2025.

A Artifact Manifest

- `app/`: Python prototype for deterministic environmental assessment.
- `cases/pci_segmented_lab/`: structured PCI-DSS-inspired case.
- `ai_bridge/`: watcher envelopes, prompts and evidence schema.
- `outputs/demo_run/`: example generated outputs.
- `tex/`: Overleaf-ready article template.

The artifact can be executed with:

```
python app/run_demo.py --case cases/pci_segmented_lab --out outputs/demo_run
```